

API Security Risk Analysis Report

Objective

To assess the security posture of publicly available API endpoints and identify potential security risks, business impacts, and remediation recommendations.

API Tested

JSONPlaceholder API

Base URL:

<https://jsonplaceholder.typicode.com>

Endpoints Tested:

- /users
- /posts

Tools Used

- Postman
- Browser Developer Tools
- JSONPlaceholder Test API

Methodology

1. Reviewed API endpoints.
2. Sent requests using Postman.
3. Examined responses and headers.
4. Analyzed authentication and authorization controls.
5. Identified security risks and documented findings.

Findings

Finding 1: Unauthenticated Access

Severity: Medium

Description:

The API endpoints can be accessed without authentication, API keys, or access tokens.

Evidence:

- GET /users
- GET /posts

Business Impact:

Unauthorized users can access exposed data without verification.

Recommendation:

Implement authentication mechanisms such as OAuth 2.0, API Keys, or JWT tokens.

Finding 2: Excessive Data Exposure

Severity: Medium

Description:

The API response exposes user-related information including email addresses, addresses, geographic coordinates, and company information.

Business Impact:

Exposed information could be used for phishing, profiling, or privacy violations.

Recommendation:

Return only necessary fields required by the application.

Finding 3: Weak Access Control Observation

Severity: Medium

Description:

Public endpoints allow unrestricted access to resources.

Business Impact:

Data may be harvested by unauthorized users.

Recommendation:

Implement role-based access control and endpoint authorization checks.

Finding 4: Rate Limiting Review

Severity: Low

Description:

The API includes rate limiting headers; however, large request volumes may still be possible.

Business Impact:

Automated requests could consume resources.

Recommendation:

Apply stricter limits for sensitive endpoints and monitor abnormal traffic patterns.

Conclusion

The API demonstrates basic functionality but exposes publicly accessible endpoints and unnecessary user information. Implementing stronger authentication, authorization, and data minimization practices would improve overall API security.